

CWE AI Working Group: New Entry Development

Meeting Minutes

April 11, 2025

Attendance

- Monika Akbar
- Kevin Monette
- Caroline Rocha
- Michael Simon
- Lee Szilagyi
- Kyle Norland
- Lee Szilagyi
- Alex Vargas
- Raymond Pompon
- Steve Christey

Agenda

- Status Updates
- Discussion of CWE-1039: Inadequate Detection or Handling of Adversarial Input Perturbations in Automated Recognition Mechanism

Meeting Notes:

Status Updates:

- **CWE 4.17 Release:** Steve announced the release of CWE 4.17 last week, highlighting the absence of new AI-related entries around insecure hyperparameters due to the need for more time and concrete demonstrative examples. However, changes were made to the adversarial perturbation CWE, including updates to consequences, descriptions, and potential mitigations.

Discussion of CWE-1039: Steve detailed the changes made CWE-1039, *Inadequate Detection or Handling of Adversarial Input Perturbations in Automated Recognition Mechanism*, including updates to consequences, descriptions, potential mitigations, and the time of introduction. Marissa Dotter contributed significantly to these updates, focusing on areas like adversarial training, model hardening, and implementation phase changes.

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CVE Program prior to publishing. Please report any inaccuracies or other issues to the CVE Program.

- **Consequences Update:** Steve explained that the consequences section of the adversarial perturbation CWE was updated to include more known issues and potential consequences.
- **Description and Name:** The description and name of CWE-1039 were updated to emphasize the weakness more clearly. The name change aimed to make the weakness more immediately recognizable and stylistically consistent with other CWE names.
- **Mitigations Added:** New potential mitigations were added, including adversarial training, model hardening, model pruning, and implementation phase changes like incorporating uncertainty estimations into algorithms.
- **Introduction Phase:** The time of introduction or the phase of the regular software development lifecycle was updated to reflect when the weakness is typically introduced. This included areas of architecture, design, and implementation phases.
- **Mapping Notes and Relationships:** Steve discussed the importance of mapping notes and relationships within CWE. He mentioned that CWE-1039 has been tagged as "with careful review of mapping notes," indicating that users should perform careful root cause analysis when mapping to the weakness.
 - **Relationship to Pillars:** CWE-1039 is a child of two different high-level pillars. Steve noted that neither of these pillars is ideal, and future work might involve creating intermediary nodes to better classify AI-related weaknesses.
- **Detection Methods and Vulnerability Mapping:** Steve highlighted the addition of detection methods and updates to vulnerability mapping notes for the adversarial perturbation CWE. He emphasized the importance of conducting careful root cause analysis and noted that some AI-related weaknesses might need intermediary classifications.
- **Future CWE Modifications:** Steve and the group discussed potential future modifications to CWE, including creating demonstrative examples and tagging additional general software weaknesses as relevant to AI and machine learning. The group agreed to prioritize mapping general software-related weaknesses first. This approach would help in creating AI-specific demonstrative examples for those general weaknesses.

- **Ontology and Classification:** Steve discussed the potential use of ontologies for CWE classification, noting that while it might make sense for some users, it doesn't fully address the mapping use case. He suggested that ontological facts could help users navigate and make better decisions when mapping weaknesses.
- **User Experience and Customization:** Monika and Steve discussed the importance of making CWE more dynamic and customizable for users. They highlighted the potential of the chatbot being developed with Chris Madden to create a more relatable experience for end users and help them navigate the CWE corpus more effectively.

Action Items:

- **Demonstrative Examples:** Collect and develop demonstrative examples specific to AI-related CWEs as they are identified. (The team)
- **NER for CWE:** Investigate the use of Named Entity Recognizers (NER) for improving CWE classification and mapping. (Michael)
- **User Experience:** Explore ways to make CWE information more dynamic and adaptive for end users, potentially through personalized views or interfaces. (The team)